

ISO27001 Checklist	Fully Implemented	Partially Implemented	Not started yet
Does the company have a formalized and communicated disciplinary process that allows you to take action to staff and other interested parties who have committed a violation of the information security policy?	☐	☐	☐
Does the company provide access to information and other related resources in accordance with the requirements regarding the provision, review, modification and removal of access rights?	☐	☐	☐
Does the company effectively manage access to external websites to limit exposure to harmful content?	☐	☐	☐
Does the company have a fixed policy regarding the control of access to information and other related resources, in accordance with the thematic policy regarding access control?	☐	☐	☐
Does the company have the process of managing and allocation of authentication information and whether the staff are properly informed about the appropriate behavior with this information?	☐	☐	☐
Has the company developed and implemented appropriate procedures for labeling information in accordance with the information classification scheme adopted by it?	☐	☐	☐
Does the company have an extensive and current register of information and other related assets, along with the mentioned owners?	☐	☐	☐
Is the planning and agreeing on audit tests and other activities ensuring the assessment of operating systems between the tester and the appropriate management?	☐	☐	☐
Does the company verify the background of all candidates for staff before joining the organization and on a regular basis, taking into account the relevant legal regulations, ethical regulations and proportionality to business requirements, classification of information to which they have access and perceived threats?	☐	☐	☐
Does the company regularly create backups of information, software and systems in accordance with the thematic policy regarding the backup and regularly test them?	☐	☐	☐
Does the company have the appropriate means of protecting wires against interception, interference or damage?	☐	☐	☐

ISO27001 Checklist	Fully Implemented	Partially Implemented	Not started yet
Does the company have changes in changes in changes in the modification of infrastructure of information processing and information systems?	☐	☐	☐
Does the company have specific and properly enforced rules regarding a clean desk for documents and portable carriers and a clean screen for information processing devices?	☐	☐	☐
Does the company regularly review compliance with information security policy, politicians on specific topics, principles and standards?	☐	☐	☐
Does the organization identify, documents, regularly reviews and sign contracts for confidentiality or non -consumption of information that reflects the need for information protection and are signed by staff and other interested parties?	☐	☐	☐
Does the company have fixed, documented, implemented, monitored and viewed configurations of hardware, software, services and networks, including security configurations?	☐	☐	☐
Does the company provide segregation of conflicting responsibilities and areas of responsibility?	☐	☐	☐
Does the company use funds to prevent data leaks on systems, networks and other devices that process, store or transmit sensitive information?	☐	☐	☐
Does the company apply data masking in accordance with the policy regarding access control and other related thematic policies and business requirements, taking into account the relevant legal provisions?	☐	☐	☐
Does the company maintain separate and secured environments for development, testing and production?	☐	☐	☐
Does the company regularly maintain equipment to ensure availability, integrity and confidentiality of information?	☐	☐	☐
Does the company provide a safe and secured place for equipment?	☐	☐	☐
Are information services, users and information systems separated in organization networks?	☐	☐	☐

ISO27001 Checklist	Fully Implemented	Partially Implemented	Not started yet
Does the company have planned, implemented, maintained and tested ICT readiness, which comply with the goals of business continuity and ICT requirements?	☐	☐	☐
Does the company regularly obtain information on the technical susceptibility of IT systems, assess its exposure to such susceptibility and undertakes appropriate preventive measures?	☐	☐	☐
Does the company have sufficient redundancy in its information processing facilities to meet the requirements for availability?	☐	☐	☐
Does the company have protection against power failures and other disturbances caused by failures in providing public services that protect its information processing objects?	☐	☐	☐
Does the company collect and analyze information on threats related to information security to generate threats intelligence?	☐	☐	☐
Does the company have documented procedures regarding response to incidents related to information security?	☐	☐	☐
Are information security policy and policy on specific topics defined, approved by the management board, published, transferred and confirmed by the relevant staff and interested parties, and regularly viewed at planned intervals and in the case of significant changes?	☐	☐	☐
Does the company identify, define and approve the requirements for information security when creating or purchasing applications?	☐	☐	☐
Does the company define, enforces and communicate responsibilities and obligations regarding information security that remain important after the end of employment or change of work?	☐	☐	☐
Was the company defined and assigned roles and responsibilities related to information security, in accordance with the needs of the organization?	☐	☐	☐
Does the company fully integrates information security in project management?	☐	☐	☐
Are the information in our company classified in accordance with the needs of the organization's information security, taking into account the confidentiality, integrity, availability and requirements of important parties interested?	☐	☐	☐

ISO27001 Checklist	Fully Implemented	Partially Implemented	Not started yet
Does the company regularly remove information stored in information systems, devices or other media when they are no longer needed?	☐	☐	☐
Does the company provide protection of information, processed or available through user end devices?	☐	☐	☐
Does the company have established rules, procedures or contracts for information transfer in all types of transfer facilities within the organization and between the organization and other parties?	☐	☐	☐
Does the company verify whether all confidential and licensed software have been deleted or securely overwritten before utilization or reuse of devices containing data carriers?	☐	☐	☐
Does the company use the acquired knowledge of incidents related to information security to strengthen and improve information security control?	☐	☐	☐
Does the company identify, documents and regularly update legal, statutory, regulatory and contractual requirements regarding information security and the organization's approach to meet these requirements?	☐	☐	☐
Does the company produce, store, protect and analyze logs that record activities, exceptions, errors and other important events?	☐	☐	☐
Does management require that all employees apply information security principles in accordance with the agreed information security policy, politicians regarding specific topics and organization's procedures?	☐	☐	☐
Does the company provide adequate protection, management and control of network and network devices to protect information in systems and applications?	☐	☐	☐
Does the company monitor networks, systems and applications to detect unusual behavior and take appropriate action to assess potential incidents related to information security?	☐	☐	☐
Does the company have appropriate protection measures for assets outside the company's headquarters?	☐	☐	☐
Are operational procedures regarding information processing in the company documented and available to the staff who need them?	☐	☐	☐

ISO27001 Checklist	Fully Implemented	Partially Implemented	Not started yet
Does the company have a specific policy regarding access control and rules on access to specific topics?	☐	☐	☐
Does the company provide appropriate procedures and monitors the return of all organization's assets in the possession of employees or other interested parties after the change or completion of employment, contract or agreement?	☐	☐	☐
Do organizational staff and significant interested parties receive appropriate training on information security awareness and regular updates of information security policy, thematic policies and procedures related to their professional function?	☐	☐	☐
Does the company have designed and implemented physical security measures for offices, rooms and objects?	☐	☐	☐
Are the rooms still monitored for unauthorized physical access?	☐	☐	☐
Does the company have fixed, documented, maintained and applied rules regarding engineering of safe systems as part of activities related to the development of IT systems?	☐	☐	☐
Has the company implemented procedures and funds to safely manage the software installation on operating systems?	☐	☐	☐
Does the company have defined and implemented processes and procedures for risk management related to the ICT product supply chain?	☐	☐	☐
Does the company have defined and implemented processes and procedures aimed at risk management related to the use of supplier products or services?	☐	☐	☐
Does the company have established processes regarding the acquisition, use, management and completion of the use of cloud services in accordance with the requirements for information security?	☐	☐	☐
Does the company provide adequate training for employees in order to raise users' awareness in the field of malware protection?	☐	☐	☐
Does the company have adequate protection measures against physical and environmental threats, such as natural disasters and other intentional or unintentional threats to infrastructure?	☐	☐	☐

ISO27001 Checklist	Fully Implemented	Partially Implemented	Not started yet
Does the company provide adequate management of access to the source code, development tools and software libraries?	☐	☐	☐
Does the company have appropriate protection measures that prevent loss, destruction, falsification, unauthorized access and unauthorized disclosure of data?	☐	☐	☐
Has the company determined and agreed the relevant requirements for information security with each supplier, taking into account the type of supplier's relationship?	☐	☐	☐
Has the company identified, documented and implemented the rules regarding acceptable use of information and procedures for servicing other related assets?	☐	☐	☐
Does the company have defined and implemented rules regarding the effective use of cryptography, including cryptographic key management?	☐	☐	☐
Does the company have established and apply the rules of safe software and systems?	☐	☐	☐
Does the company have established and implemented rules regarding the control of physical and logical access to information and other related resources, in accordance with business requirements and information security?	☐	☐	☐
Does the company have adequate input checks and access points that protect areas marked as safe?	☐	☐	☐
Has the company implemented technologies and safe authorization procedures, taking into account the limitations of access to information and the thematic policy regarding access control?	☐	☐	☐
Does the company apply the rules of safe coding during the software creation process?	☐	☐	☐
Does the company have designed and implemented security measures for employees working in protective areas?	☐	☐	☐
Has the company implemented security measures when the staff work remotely to protect available information, processed or stored outside the organization?	☐	☐	☐

ISO27001 Checklist	Fully Implemented	Partially Implemented	Not started yet
Does the company identify, implement and monitor security mechanisms, services levels and requirements for network services?	☐	☐	☐
Does the company define and use security circuits to protect areas containing information and other related assets?	☐	☐	☐
Does the company have defined and implemented safety testing processes in the project life cycle?	☐	☐	☐
Does the company manage memory carriers in a manner consistent with the life cycle, covering the processes of their acquisition, use, transport and removal, taking into account the classification and requirements for their operation?	☐	☐	☐
Does the company provide adequate selection, protection and management of test information?	☐	☐	☐
Does the company limit and manage the granting and use of privileged access rights?	☐	☐	☐
Are the clocks of information processing systems used by the organization synchronized with approved sources of time?	☐	☐	☐
Does the employment contract contain precise provisions regarding the responsibility of staff and organization for information security?	☐	☐	☐
Is the company able to manage the full identity cycle?	☐	☐	☐
Does the organization assess events related to information security and decide whether they qualify as incidents related to information security?	☐	☐	☐
Does the organization direct, monitor and review activities related to external system development?	☐	☐	☐
Does the company have established and implemented procedures regarding the identification, collection, acquisition and maintenance of evidence related to events related to information security?	☐	☐	☐
Does the organization maintain contact with the relevant authorities?	☐	☐	☐
Does the company maintain contact with groups with special interests or other specialist security forums and professional associations?	☐	☐	☐

ISO27001 Checklist	Fully Implemented	Partially Implemented	Not started yet
Does the organization identify and meet the requirements for the protection of the privacy and protection of personal data (PII) in accordance with applicable legal regulations, regulations and contractual requirements?	☐	☐	☐
Does the company have appropriate procedures to protect intellectual property rights?	☐	☐	☐
Did the organization define, establish and communicate processes, roles and responsibilities related to the management of incidents related to information security?	☐	☐	☐
Does the organization have a set plan on how to maintain an adequate level of information security in case of interference?	☐	☐	☐
Does the organization provide staff with an appropriate mechanism for reporting observed or suspicious events related to information security through the relevant channels on time?	☐	☐	☐
Does the organization regularly monitor, review, evaluate and manage changes in the security of information provider and provision of services?	☐	☐	☐
Does the organization regularly conduct independent reviews of its approach to information security and implementation, including people, processes and technologies in accordance with planned dates or in case of significant changes?	☐	☐	☐
Does the company monitor and adapt the use of resources in accordance with the current and expected capacity requirements?	☐	☐	☐
Does the company have strict and controlled restrictions on the use of tool programs that can bypass system controls and applications?	☐	☐	☐

Please share! Its Free to use. Just tag me:

author: @wojciech ciemski

Follow me for more Security Content!

Its based on ISO/IEC 27001:2022